



Facultad de Estadística e Informática
Cómputo en la nube



Proyecto Final

Caso de negocio

Clínica FEI+

Objetivo: Que el estudiante demuestre los conocimientos aprendidos durante el semestre en un ambiente práctico.

Participantes: El proyecto podrá ser realizado por equipos de hasta 4 personas

1. Contexto de la organización

1.1 Quiénes somos

Clínica FEI+ es una red de atención médica privada en la ciudad de Xalapa, Veracruz. A lo largo de los años de operación ha crecido de una sola clínica de consulta general a una red de cuatro sedes ubicadas en Xalapa, Veracruz, Coatepec y Orizaba. Actualmente atiende a más de 38,000 pacientes registrados y procesa en promedio 420 consultas diarias entre sus especialidades de medicina general, pediatría, ginecología, cardiología y laboratorio clínico.

La organización cuenta con 180 colaboradores directos, incluyendo personal médico, administrativo y de soporte técnico. Su facturación anual supera los 45 millones de pesos y mantiene convenios activos con tres aseguradoras nacionales que requieren intercambio electrónico de expedientes clínicos.

1.2 El contexto

Durante los últimos tres años, Clínica FEI+ ha crecido de forma acelerada pero sus sistemas de información no han seguido el mismo ritmo. Hoy, la organización opera con una mezcla de soluciones que fueron resolviendo problemas inmediatos en su momento, pero que en conjunto representan un riesgo operativo y de seguridad que la dirección ya no puede ignorar.

Situación actual de infraestructura

- Servidor físico propio en Xalapa (9 años de antigüedad) que aloja el sistema de expedientes clínicos.
- Tres servidores NAS en cada sede foránea para almacenar estudios de laboratorio e imágenes médicas.
- Sistema de agendamiento de citas desarrollado a medida en 2015, sin mantenimiento desde 2019.
- Acceso remoto de médicos mediante VPN configurada por un proveedor externo que cerró operaciones en 2022.
- Copias de seguridad manuales en discos duros externos realizadas de forma irregular.
- Cuatro sistemas de facturación distintos, uno por sede, sin integración entre ellos.
- Comunicación interna por correo electrónico corporativo y WhatsApp personal de los empleados.

1.3 El reto

El pasado mes de octubre, durante una auditoría de cumplimiento solicitada por una de las aseguradoras, se detectaron tres hallazgos críticos que pusieron en pausa la renovación del convenio más importante de la empresa:

1. El sistema de expedientes clínicos transmite información de pacientes sin cifrado entre las sedes.
2. No existe un registro de auditoría que permita identificar quién accedió o modificó un expediente.
3. Los estudios de laboratorio de pacientes son accesibles desde cualquier computadora de la red interna sin autenticación.

La aseguradora otorgó a Clínica FEI+ un plazo de seis meses para demostrar que su infraestructura tecnológica cumple con los estándares mínimos de seguridad de la información en el sector salud. De no hacerlo, el convenio — que representa el 28% de los ingresos anuales — no será renovado.

Ante esta situación, el Director General convocó a la Directora de Tecnología y al área financiera a una reunión de emergencia. El consenso fue claro: no tiene sentido seguir parcheando una infraestructura obsoleta. Es el momento de hacer una renovación, pero hacerlo bien, no de prisa. Por lo que se deben analizar diferentes tecnologías incluido el uso de servicios de nube.

2. El proyecto

La Directora de Tecnología ha contratado a su equipo — ustedes — como consultores especializados en seguridad y arquitectura en la nube. El encargo tiene dos dimensiones claramente definidas:

Dimensión 1 Análisis y estrategia Entender la situación real de la organización, identificar los riesgos, y proponer una arquitectura de solución técnica que responda a las necesidades del negocio con seguridad integrada desde el diseño.	Dimensión 2 Implementación demostrable Construir en la nube un entorno funcional que implemente los controles de seguridad que su propuesta plantea, y que sea capaz de resistir una auditoría básica ante el cliente.
---	--

Su trabajo no consiste únicamente en aplicar tecnología. Consiste en analizar cada decisión técnica y como ésta responde a un requisito de negocio o a un riesgo identificado. Clínica FEI+ no quiere que les instalen servicios, quiere entender qué están comprando y por qué solucionará sus problemas.

3. Requisitos del negocio

La Directora de Tecnología les entrega el siguiente conjunto de necesidades tal como las expresó el equipo directivo. No son especificaciones técnicas: son preocupaciones reales del negocio que su propuesta debe atender.

3.1 Continuidad operativa

La clínica no puede permitirse una interrupción de más de cuatro horas en el acceso a expedientes clínicos durante horario de atención. Cualquier falla en una sede no debe afectar la operación de las otras tres. Hoy, si el servidor de Xalapa falla, todas las sedes quedan sin sistema.

3.2 Control de acceso a información sensible

Los expedientes clínicos son información protegida por la Ley General de Salud. Solo el médico tratante y el personal autorizado por el paciente deben poder consultar su expediente. Un médico de cardiología no debería ver los expedientes de ginecología. Un administrativo no debería poder abrir ningún expediente clínico.

3.3 Trazabilidad completa

La aseguradora exige poder responder, ante cualquier incidente, las preguntas: ¿quién accedió al sistema?, ¿qué información consultó o modificó?, ¿desde dónde y cuándo? Esta trazabilidad debe conservarse por al menos dos años y no debe ser modificable por ningún usuario del sistema, ni siquiera por los administradores.

3.4 Protección de datos en movimiento y en reposo

Los estudios de laboratorio, imágenes médicas y expedientes clínicos representan la información más sensible de la organización. Deben estar protegidos tanto cuando se almacenan como cuando viajan entre las sedes y los dispositivos del personal médico. El robo físico de un equipo no debe comprometer la información de los pacientes.

3.8 Integración con terceros de forma controlada

Tres aseguradoras intercambian expedientes y resultados de laboratorio con Clínica FEI+ de forma electrónica. El mecanismo actual es un servidor FTP con credenciales compartidas. Se necesita una forma de que estos intercambios sean seguros, auditables y controlados, sin exponer la red interna de la clínica.

4. Restricciones y consideraciones del proyecto

Restricciones que su propuesta debe respetar

Presupuesto: El Director Financiero aprobó inicialmente solo servicios de nivel gratuito o de muy bajo costo para el prototipo. La propuesta de costos para producción debe ser justificada.

Regulación: Clínica FEI+ opera en México. Su solución debe considerar la Ley Federal de Protección de Datos Personales en Posesión de Particulares (LFPDPPP) y la NOM-024-SSA3.

Continuidad del negocio: La migración no puede implicar una interrupción total. El plan debe contemplar coexistencia con los sistemas actuales durante la transición.

Personal técnico: La clínica solo cuenta con un técnico de soporte interno sin experiencia en nube. La solución debe ser operable con ese perfil, o incluir una propuesta de capacitación.

Residencia de datos: La aseguradora principal exige que los datos de pacientes residan en territorio mexicano o en centros de datos con certificación equivalente.

5. Fases del proyecto y entregables

Fase 1 — Análisis y propuesta arquitectónica

En esta fase su equipo debe estudiar el caso con profundidad, identificar los riesgos reales de la organización y proponer una arquitectura de solución argumentada. No se espera que la solución sea perfecta, se espera que sea razonada.

Entregable 1.A — Análisis de riesgos

Documento estructurado que identifique los activos de información críticos de Clínica FEI+, las amenazas que los afectan, las vulnerabilidades actuales y el impacto potencial para el negocio. El análisis debe priorizar los riesgos y justificar esa priorización.

Entregable 1.C — Propuesta fundamentada

Relación de soluciones tecnológicas propuestas para el cumplimiento de los requisitos de la organización y el por qué de estos. Fundamenta las decisiones técnicas de la propuesta respecto de la atención a la auditoría.

Entregable 1.B — Propuesta de arquitectura

Diagrama de arquitectura anotado que muestre cómo quedaría la infraestructura en la nube, incluyendo separación de componentes, flujos de datos, puntos de control de seguridad y mecanismos de acceso. Cada elemento del diagrama debe estar justificado en función de los requisitos del negocio descritos en la Sección 3.

Entregable 1.D — Modelo de responsabilidad compartida aplicado al caso

Tabla que mapee explícitamente qué controles de seguridad son responsabilidad del proveedor de nube y cuáles son responsabilidad de Clínica FEI+ en el modelo que proponen. Incluir un análisis de las implicaciones regulatorias (LFPDPPP, NOM-024-SSA3).

Fase 2 — Implementación del entorno seguro

Con base en la propuesta, el equipo construye el entorno en la nube. Lo que se implemente debe poder demostrarse.

Ambiente de nube operativo que incluya al menos los controles asociados a los requisitos críticos del negocio. El entorno debe ser accesible y demostrable en tiempo real.

6. Criterios de evaluación

La calificación del proyecto se distribuye de la siguiente manera. Nótese que el peso mayor está en la justificación y el análisis, no en la implementación técnica per se.

#	Entregable	Qué se evalúa	Peso
1.A	Análisis de riesgos	Profundidad del análisis, pertinencia de los riesgos identificados y calidad de la priorización.	20%
1.C	Propuesta fundamentada	Coherencia entre requisitos de negocio y decisiones técnicas.	20%

#	Entregable	Qué se evalúa	Peso
1.B	Propuesta de arquitectura	Claridad del diagrama y justificación de cada componente.	30%
1.C	Modelo de responsabilidad	Correcta delimitación de responsabilidades y comprensión del marco regulatorio aplicable.	10%
2.A	Entorno funcional	Los controles de seguridad propuestos existen, funcionan y son demostrables en tiempo real.	20%

Criterios adicionales

En todos los entregables se evaluará si las decisiones técnicas están argumentadas en función del negocio.

No se permite la entrega únicamente de la propuesta documental o de la implementación técnica, ambos elementos deben realizarse, aunque no se encuentren al 100%.

Una solución incompleta pero bien argumentada y con documentación honesta de sus limitaciones puede alcanzar una calificación satisfactoria.